Report Tecnico Targeted Attack & Post-Exploitation Forensic Analysis

Target: Metasploitable 2 (`192.168.50.102`)

Attaccante: Kali Linux (`192.168.50.101`)

Data: 10 Aprile 2026

---

1. Introduzione e Metodologia (Cyber Kill Chain)

L'obiettivo è dimostrare l'inefficacia delle difese basate su password deboli quando l'attaccante utilizza tecniche di **Targeted Wordlist Generation**. L'operazione segue le fasi della *Cyber Kill Chain*:

1. **Reconnaissance:** Identificazione servizi (SSH/FTP).
2. **Weaponization:** Creazione di dizionari customizzati tramite OSINT e profilazione.
3. **Exploitation:** Attacco brute-force mirato con Hydra.
4. **Forensic Analysis:** Studio delle tracce lasciate sui log di sistema.

---

2. Fase di Reconnaissance & Profiling OSINT

L'efficacia di un attacco dipende dalla riduzione dello spazio di ricerca (search space). Abbiamo ipotizzato un target con legami culturali specifici (Napoli, Italia).

A. Estrazione Keyword con CeWL

Abbiamo scansionato il web server locale per estrarre il lessico aziendale:

```
cewl -d 2 -m 5 -w web_seeds.txt http://192.168.50.102/mutillidae/
```

B. Profilazione Personale (CUPP) ed Entropia

Utilizzando **CUPP**, abbiamo profilato il sistemista ipotetico "Antonio Ruocco".

> Una password casuale di 8 caratteri ha un'entropia calcolata come $H = L \cdot \log_2(R)$. Utilizzando liste mirate, l'attaccante riduce drasticamente R (il set di caratteri probabili), rendendo il cracking migliaia di volte più veloce rispetto a un attacco *pure brute-force*.

Nota Tecnica: L'Entropia di Hartley (H)

Per valutare la robustezza delle credenziali analizzate, abbiamo utilizzato il concetto matematico di **Entropia di Hartley**, che misura la resistenza di una password a un attacco di brute-force.

La formula applicata è:

$$H = L \cdot \log_2(R)$$

Dove:

- L **(Lunghezza):** Il numero totale di caratteri nella password.
- R **(Range/Pool):** Il numero di caratteri possibili per ogni posizione (es. $R = 10$ per soli numeri, $R = 95$ per l'intero set ASCII).
- H **(Entropia):** Il valore risultante espresso in **bit**. Un valore di H più alto indica che un attaccante deve testare 2^H combinazioni per avere la certezza del successo.

Mentre una password casuale di 10 caratteri presenta un'entropia elevata (≈ 65 bit), l'uso di **Targeted Wordlists** (tramite CeWL e CUPP) permette all'attaccante di ridurre drasticamente il valore "effettivo" di R. Concentrandosi solo su termini legati al contesto del target, lo spazio di ricerca diminuisce, portando l'entropia reale a pochi bit e rendendo il cracking con Hydra quasi istantaneo, indipendentemente dalla complessità teorica della password.

---

3. Weaponization: Mutazione e Raffinamento

Per superare le policy di sicurezza (es. "Almeno una maiuscola e un numero"), abbiamo applicato regole di mutazione ai seed raccolti.

- **Hashcat Mutation Rules:** Abbiamo applicato la `best64.rule` per generare varianti dinamiche (es. `Napoli` -> `Napoli123`, `N@poli!`).

  ```
  hashcat --force -r /usr/share/hashcat/rules/best64.rule web_seeds.txt --
  stdout > final_wordlist.txt
  ```

- **Pattern Matching con Crunch:** Sapendo che le policy spesso richiedono l'anno corrente:

  ```
  crunch 10 10 -t @@@@@@2026! -p Gennaio Febbraio Marzo >
  calendar_wordlist.txt
  ```

---

4. Exploitation: Attacco Multistrato (SSH/FTP)

Abbiamo eseguito l'attacco prestando attenzione alla **Operational Security (OpSec)**.

```
# Attacco SSH con thread limitati per evitare il Denial of Service del servizio
hydra -L users.txt -P final_wordlist.txt ssh://192.168.50.102 -t 4 -V
```

Nota OpSec:

Per rendere l'attacco meno rilevabile dai sistemi di monitoraggio, è stato utilizzato un numero ridotto di thread (`-t 4`). Un valore troppo alto (es. `-t 64`) causerebbe un picco anomalo di connessioni `SYN_SENT` nei log del firewall.

---

5. Analisi Forense e Blue Teaming

Questa fase simula l'investigazione post-compromissione.

A. Analisi dei Log di Autenticazione

Analizzando `/var/log/auth.log` sulla Metasploitable, sono stati isolati gli indicatori di compromissione (IoC):

Indicatore	Dettaglio Tecnico	Evidenza Log
Sorgente Attacco	IP 192.168.50.101	`rhost=192.168.50.101`
Tecnica	Password Spraying / Brute Force	Centinaia di `Failed password` in < 60s
Compromissione	Login effettuato con successo	`Accepted password for msfadmin`

B. Analisi del Traffico (Network Forensics)

Utilizzando `tcpdump` o Wireshark, è stata evidenziata una differenza critica tra i protocolli:

- **FTP (Porta 21):** Le credenziali sono state intercettate **in chiaro** nel pacchetto `USER` e `PASS` .
- **SSH (Porta 22):** Il traffico è cifrato; l'analista vede solo il volume di dati, ma non la password.

Comando per monitorare tentativi in tempo reale:

```
tail -f /var/log/auth.log | grep -i "failed"
```

---

6. Mitigazione e Strategie Difensive

Per proteggere l'infrastruttura da attacchi così mirati, sono state proposte le seguenti contromisure:

1. **Hardening del Servizio:** Disabilitare il login root via SSH e cambiare la porta di default (22).
2. **Controllo degli Accessi:** Implementare **Fail2Ban** per il ban automatico degli IP dopo 3 tentativi falliti.
3. **Dizionario Proibito:** Inserire le keyword aziendali (ottenute tramite CeWL) in una *blacklist* sul Domain Controller per impedire agli utenti di usarle come password.
4. **Monitoraggio Attivo:** Configurare un SIEM per allertare il team di sicurezza in caso di picchi di tentativi `RST` (Reset) su porte di autenticazione.

---

7. Post-Exploitation: Privilege Escalation

Una volta ottenute le credenziali tramite Hydra e stabilita una sessione SSH, l'attacco è proseguito con la fase di **Privilege Escalation (Verticale)**. L'obiettivo è passare da un utente con privilegi limitati (`msfadmin`) al controllo totale del sistema (`root`).

A. Enumerazione del Sistema

Abbiamo analizzato la macchina alla ricerca di vettori di attacco comuni su sistemi Linux datati come Metasploitable 2:

- **Kernel Exploitation:** Verifica della versione del kernel tramite `uname -a`. Molte versioni vecchie sono vulnerabili a exploit come *Dirty COW*.
- **SUID Binaries:** Ricerca di file con il bit SUID impostato, che permettono a un utente normale di eseguire file con i privilegi del proprietario (root). Bash
  ```
  find / -perm -4000 -type f 2>/dev/null
  ```
- **Misconfigurazioni sudo:** Verifica dei permessi dell'utente corrente tramite `sudo -l`. (In Metasploitable 2, spesso l'utente `msfadmin` può eseguire molti comandi senza password).

B. Esecuzione dell'Escalation

Nel caso specifico di Metasploitable 2, una delle vulnerabilità più celebri riguarda il servizio **distcc** o la presenza di script scrivibili in **cron jobs**. Un attaccante potrebbe inserire una *Reverse Shell* in un file eseguito periodicamente da root per ottenere una shell amministrativa.

C. Impatto Forense della Privilege Escalation

La scalata dei privilegi lascia tracce molto diverse dal brute-force:

1. **Log di Sudo:** Ogni tentativo (riuscito o fallito) di usare `sudo` viene registrato in `/var/log/auth.log`.
2. **Bash History:** Se l'attaccante non pulisce i propri file, il comando `history` rivelerà tutti i tentativi di escalation effettuati.
3. **Nuovi Utenti/Backdoor:** Un amministratore attento noterà la creazione di nuovi utenti con UID 0 o la modifica del file `/etc/shadow`.

Conclusioni

> **Considerazioni Finali:** L'esercitazione ha dimostrato che la sicurezza di un sistema non è un elemento statico ma una catena. Un anello debole nella gestione delle password (scarsa entropia reale causata da pattern prevedibili) ha permesso l'accesso iniziale. Tuttavia, è la fase di **Privilege Escalation** a rappresentare il rischio maggiore: una volta "dentro", le vulnerabilità del kernel e le misconfigurazioni dei permessi trasformano un accesso limitato in una compromissione totale della riservatezza, integrità e disponibilità dei dati (CIA Triad).
>
> **Raccomandazione Proattiva:** Oltre a una corretta politica delle password, è fondamentale il **Patch Management** costante per chiudere i vettori di escalation che trasformano un semplice utente in un amministratore malintenzionato.

8. Fase di Defense Evasion (Anti-Forensics)

In uno scenario reale, dopo aver ottenuto i privilegi di root, un attaccante cercherebbe di nascondere le proprie tracce per mantenere la persistenza senza essere rilevato dal Blue Team.

A. Manipolazione della Bash History

Il primo passo per nascondere i comandi digitati è disabilitare o ripulire il file della cronologia:

```
unset HISTFILE          # Impedisce la scrittura dei comandi correnti su disco
history -c              # Pulisce la sessione corrente
rm ~/.bash_history      # Elimina fisicamente il file dei log dei comandi
```

B. Timestomping

L'attaccante potrebbe usare il comando `touch` per modificare le date di accesso e modifica dei file creati (es. una backdoor), rendendo difficile l'analisi forense basata sulla timeline:

```
touch -r /etc/passwd /tmp/backdoor.sh  # Copia i timestamp di un file di
sistema sulla backdoor
```

C. Analisi dell'Efficacia Forense

Nonostante questi tentativi, abbiamo osservato che:

- I log di sistema (come quelli inviati a un server **Syslog** esterno) sono difficili da cancellare se l'attaccante non compromette anche il server di logging.
- Le connessioni attive rimangono visibili nella tabella di routing e nei socket (`netstat -antp`), a meno di non utilizzare rootkit avanzati.